AI Tools & Your Business

A guide to choosing the right AI setup for your company

For informational purposes only — not legal advice

Last verified: February 2026

Your team is already using AI.

The question is whether you know how.

Just ChatGPT

No official tools
Employees use free tiers
No policy, no oversight
You think you're not doing AI

Wild West

Too many tools
Every team picked their own
No coordination
Nobody checked the data policies

Engineering. Finance. Marketing. Operations. Everyone.

AI is every department’s problem now.

So what's the risk?

Samsung engineers pasted proprietary code into ChatGPT.

Company-wide ban followed.

Business Insider, 2023

72,000 photos.
13,000 government IDs.
Leaked to 4chan.

Lawfare, 2025

€15M

first GDPR fine targeting
a generative AI company

Reuters, Dec 2024

None required a sophisticated attack.

Five rules every decision maker needs to know.

The rules that matter

1. **Typing data into an AI tool = processing it**
   GDPR applies the moment personal data enters a prompt

2. **Your company is liable, not the tool**
   You're the data controller. The AI provider is the processor.

3. **Free tiers are a different legal world**
   No DPA, may train on your data, no deletion controls

4 Data has to stay protected when it crosses borders

A DPA governs the relationship. It doesn’t control geography.

5 AI literacy training is now law

EU AI Act Article 4. Enforceable now. Not a suggestion.

Fines: up to 4% global turnover (GDPR) or 7% (EU AI Act)

Paying ≠ protected.

The tier matters. Not the price tag.

Consumer Tiers

Training allowed
No DPA
No deletion controls

Enterprise Tiers

No training (contractual)
DPA with EU SCCs
Compliance controls

So which tiers,
from which providers?

The provider landscape

Last verified: February 2026

	OpenAI	Anthropic	Google	Microsoft
General use	ChatGPT	Claude.ai	Gemini	Copilot
Coding	Codex	Claude Code	Code Assist	GitHub Copilot
No-training tier	Business / Enterprise	Team / Enterprise / API	Workspace / Vertex	M365 / GH Business+

Compliance & data residency

	OpenAI	Anthropic	Google	Microsoft
DPA	Business / Enterprise / API	Team / Enterprise / API	Workspace / Vertex	M365 / Azure / GH Business+
EU residency	Enterprise / Edu + API	No direct (via GCP / AWS)	Native (10+ EU regions)	EU Boundary + Azure
Transfer	SCCs (no DPF)	SCCs (Ireland entity)	CDPA	DPA + EU Boundary

A DPA ≠ data residency.

One governs the relationship.
The other controls the geography.

DPA + SCCs

Legally defensible
Same as Salesforce, M365
Data goes to US servers
SCCs invalidated twice before

EU Data Residency

Data never leaves the EU
No cross-border transfer
No Schrems-style risk
Stronger regulatory posture

11%

of data pasted into ChatGPT
is sensitive

Cyberhaven

Assume PII will enter your tools.

Make the default path safe enough that it doesn’t matter.

Any model, any cloud, EU-resident.

Claude on GCP · Claude on AWS · Azure OpenAI · M365 Copilot

Everyday Use

Email, research, analysis
Customer names will enter
No enforceable boundary

→ Default to EU-resident

Coding

You control the data
Test data → enterprise tier
Production data → EU-resident

→ Two paths possible

The boundary only works for code.

Marketing drafting a client email → **PII enters**

Ops evaluating a customer claim → **PII enters**

Engineering coding with test data → **no PII**

Engineering debugging production → **PII enters**

Time for the actual decision.

Five questions to ask before any vendor conversation

1. What data touches the tool?
2. Where are your customers?
3. Engineering vs everyone else?
4. How many tools can you manage?
5. What’s your compliance maturity?

The Recommended Setup

A concrete starting point

EU Companies

Assume PII will enter.
Default to EU-resident.

General use:
Google Workspace Gemini

Coding:
Claude Code via Vertex AI

Non-EU Companies

Enterprise tier + DPA
as the baseline.

General use:
Claude Team
or ChatGPT Business

Coding:
Claude Code (Team/API)

Free tiers are not approved for work. Full stop.

What your AI policy needs

A starting point — adapt with your legal team

1. **Approved tools list** Which tools, which tiers. Living document.
2. **Data classification** What can vs cannot go into AI tools.
3. **The two-path rule** General work vs PII-safe setup.
4. **Incident reporting** PII in unapproved tool = potential breach. 72-hour notification.
5. **AI literacy training** EU AI Act Article 4. Legal requirement.
6. **Roles & responsibilities** Who approves, monitors, responds.

And remember...

The gap between using AI safely and using AI recklessly isn’t about which model is smartest.

It’s about which setup you choose — and whether you choose at all.